UNIVERSITE LIBRE
DE BRUXELLES

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Ch. Cuvelliez – Feb 11 & Feb 12

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Authentication is the process of verifying the identity of either a user or a device, before authorising access to devices or services

Why authenticate?

- User authentication is the main method for protecting against unauthorised access to devices and the data stored + protecting against unauthorised changes to device settings.
- Enterprise services will be accessed from devices: therefore
  1. **Verify the user's identity on each device so only authorised people can access services**.
  2. **For services with sensitive data, also verify the device's identity** and security health to block non-compliant devices (For services with sensitive data)
  3. **Attackers exploit weaknesses in authentication**, often using simple methods to guess or steal user or device credentials.

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Authentication use cases

- **User to device**: The user is only granted access to the device after successfully authenticating to it.
- **User to service**: The user is only able to access enterprise services after successfully authenticating to the service, via their device.
- **Device to service**: Only devices which can authenticate to the enterprise are granted access.

Authentication Method	User to device
Passwords or PINs	Passwords or PINs usual primary method for user to device authentication. **Risks**: guess or brute force. **Necessity to have technology to protect against offline brute force attack**, limiting the ability of an attacker to repeatedly guess passwords or PINs. **PIN on device is like-MFA** (you know/you have): knowledge of PIN is only useful if the attacker also has physical access to the device.
Biometrics	Smartphones, tablets, laptops, and desktops now also have biometric authentication (fingerprint and face recognition). These can offer convenient and secure alternatives to passwords but passwords and PIN are the only mechanism without false positive/false negatives

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Authentication use cases

- **User to device**: The user is only granted access to the device after successfully authenticating to it.
- **User to service**: The user is only able to access enterprise services after successfully authenticating to the service, via their device.
- **Device to service**: Only devices which can authenticate to the enterprise are granted access.

Authentication Method	User to service / device to service
Passwords or PINs	• Passwords : most **common user-to-service authentication** method due to their **ease of implementation.** • Users often reuse passwords or choose common ones, leading to vulnerabilities like password spraying or brute force attacks. • Passwords are susceptible to phishing, spear-phishing, and server-side credential theft, as seen in numerous data breaches.. • **Password deny lists, organizational password policies, and creating secure passwords**
Certificates	• Long-term credentials with a private key and signed public key. Access to the private key is required to authenticate to other services and can be used to authenticate the device or the user to the service. • The private key **to be protected from access by malicious software (via sandboxing or other access control mechanism, including marking it non-exportable)** + be **protected from hardware extraction by** the device's data-at-rest encryption, or a strong encryption password if it can't be otherwise protected.

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Authentication use cases

- **User to device**: The user is only granted access to the device after successfully authenticating to it.
- **User to service**: The user is only able to access enterprise services after successfully authenticating to the service, via their device.
- **Device to service**: Only devices which can authenticate to the enterprise are granted access.

Authentication Method	User to service / device to service
FIDO 2	• **Passwordless authentication standard using public key cryptography** to verify user identities instead of shared secrets like passwords: eliminates common credential theft or phishing risks. 1. **Registration Phase** • The user registers with a FIDO2-supported service (" a relying party") through a device that acts as a client. • Upon approval (using a biometric scan, PIN, or tap), the device's authenticator generates a unique public-private key pair linked specifically to that account and domain. • The public key is sent to the online service - the private key remains securely stored on the local device (never transmitted) **2. Authentication Phase** • When logging in, the server **sends a cryptographic challenge to the client.** • The authenticator uses the private key to sign that challenge, creating a digital proof of possession without revealing the key itself. • The server **verifies the signature using the stored public key**, confirming both the device and user's authenticity.

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Authentication use cases

- **User to device**: The user is only granted access to the device after successfully authenticating to it.
- **User to service**: The user is only able to access enterprise services after successfully authenticating to the service, via their device.
- **Device to service**: Only devices which can authenticate to the enterprise are granted access.

Authentication Method	User to service / device to service
FIDO 2	**Authenticators** Platform Authenticators: Built into a device (like Windows Hello or Touch ID). Roaming Authenticators: External keys or devices (like YubiKeys or smartphones) connected via USB, NFC, or Bluetooth. **Security and Privacy Advantages** • Eliminates **password reuse and phishing vulnerabilities** because **private keys never leave the device.** • Protects users from server breaches, since compromised databases only contain useless public keys. • Supports multifactor models by combining user gestures or biometrics with cryptographic tokens.

FIDO2 shifts authentication from knowledge-based credentials (passwords) to possession-based and biometric verification, providing strong, phishing-resistant, and user-friendly security across web and mobile platforms.

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Single factor vs Multi-factor Authentication for services

- **Single factor may be appropriate:** e.g user to device authentication, use of a single factor to authenticate to the device may be enough (because of mitigations such as brute force protection or hardware protected storage, available on many of today's devices).

- Enterprise authentication services can integrate with Mobile Device Management (MDM) to assess environmental factors like network location, device compliance, and device health before granting access.

- This conditional access approach is highly effective in zero-trust network architectures and bring-your-own-device (BYOD) scenarios

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

Single Sign On

- Enterprise single sign-on (SSO) enables users to access online services using **a single identity managed by the chosen identity provider.**
- It **improves user experience by minimizing repeated authentications** and **reducing password reliance**.
- SSO **simplifies managing joiners, movers, and leavers**, making the process less error-prone.

Logging and monitoring

- Enable monitoring of authentication and access to devices and services:
  - Attacks on authentication systems are the most prevalent
  - Capturing these events = highly effective way of detecting potential issues.

DEVICE SECURITY GUIDANCE

ENTERPRISE AUTHENTICATION POLICY

When designing and implementing enterprise authentication:

- Select an enterprise identity provider supporting MFA for users and devices; configure SSO for online services with that identity provider.
- Deploy enterprise SSO with strong user/device authentication via MFA or conditional access.
- Choose usable, secure authentication factors supported by organizational devices.
- Provide clear authentication policies and user guidance.
- Implement **pragmatic user-to-device authentication with biometrics and usable password policies**.
- **Reduce password reliance:** adopt passwordless options like Windows Hello where possible + Encourage password managers when passwords are required.
- For machine authentication, use **hardware-protected public key credentials bound to devices**, combined with **context like network location, compliance, and health attestation.**

DEVICE SECURITY GUIDANCE

VIRTUAL PRIVATE NETWORKS (VPNS)

Virtual Private Networks (VPNs) allow organisations to provide secure connectivity between devices in physically separate locations:

Why use a VPN?

1. **Enabling legacy systems to work remotely**
   - ✓ making outdated or traditional enterprise systems accessible over the internet or from outside the office network.
2. **Providing a second layer of defence against misconfigured, unpatched, or poorly designed internal services**
   - ✓ Intranet websites that aren't well maintained, or use legacy cryptography
3. **Protecting internal network servers from external, unauthenticated attackers,**
   - ✓ By limiting network access to authenticated devices. For example, file stores or databases
4. **Protecting user devices from network attacks**
   - ✓ By preventing direct connections to and from the local network. For example, ARP spoofing attacks, or attacking open network interfaces on the mobile device

DEVICE SECURITY GUIDANCE

VIRTUAL PRIVATE NETWORKS (VPNS)

Virtual Private Networks (VPNs) allow organisations to provide secure connectivity between devices in physically separate locations:

Why use a VPN?

1. **Enabling legacy systems to work remotely**
   - ✓ making outdated or traditional enterprise systems accessible over the internet or from outside the office network.
2. **Providing a second layer of defence against misconfigured, unpatched, or poorly designed internal services**
   - ✓ Intranet websites that aren't well maintained, or use legacy cryptography
3. **Protecting internal network servers from external, unauthenticated attackers,**
   - ✓ By limiting network access to authenticated devices. For example, file stores or databases
4. **Protecting user devices from network attacks**
   - ✓ By preventing direct connections to and from the local network. For example, ARP spoofing attacks, or attacking open network interfaces on the mobile device

DEVICE SECURITY GUIDANCE

PREPARATION FOR VPN USE

1. **There would be little benefit in using a VPN if you've fully adopted a zero-trust approach to networking**

2. **Legacy services may not be needed on devices outside the firewall, or blocking access to illegal websites could be done on-device, if required**

3. **In case of a walled garden architecturethat requires end users' traffic to traverse untrusted networks and external firewalls then you should consider using a VPN**

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

Transport Layer Security (TLS) and Internet Protocol Security (IPsec).

1. Other protocols, such as **Wireguard are growing in popularity** and seem promising, but are yet to be proven in enterprise contexts.
2. **IPsec be used for VPN access. IPsec is an open standard,** meaning that anyone can build a client or server which will work with other IPsec implementations.
3. **As an IPsec VPN client is built into many operating systems, no additional products are required to deploy a VPN.** However, some third-party networks restrict or block IPsec traffic, so your mobile devices may, in certain situations, be unable to create the VPN connection.
4. **TLS VPNs can also be used**, but need to use a third-party client and server.
   - **Products from different vendors will rarely inter-operate**: need to use both from the same vendor.
   - **TLS is standardised in a variety of RFCs, but how those protocols are used to create a VPN is not**. TLS VPN connections can be more reliable when traversing Network Address Translation (NAT) devices, or enterprise firewalls

Why TLS VPNs Traverse NAT and Firewalls Better

- TLS-based VPNs (SSL VPNs) use TCP port 443, same as HTTPS, so firewalls rarely block it, allowing seamless passage as normal web traffic.
- This encapsulation makes VPN sessions mimic encrypted browsing, ideal for restrictive networks.
- NAT compatibility: TLS VPNs work well with NAT since they use TCP headers that adapt to port reassignments.
- IPsec struggles with NAT because ESP/AH lack TCP/UDP headers, disrupting static IP dependencies and packet handling.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between IPSec, Wireguard, TLS VPN – What are the criteria to consider ?

1. **Protocol nature and OSI layer**

- **WireGuard:** modern, fixed-suite VPN protocol in the kernel that encapsulates IP over UDP, operating at layer 3.
- **IPsec is a suite of standards that adds security at the IP layer (layer 3),** with AH/ESP and IKE for key management.
- **TLS-based VPNs (often called SSL VPNs like OpenVPN, HTTPS VPNs) run over TCP or UDP on top of TLS** at layers 4–7.

2. **Cryptography and code surface**

- WireGuard: fixed, opinionated modern crypto set (Curve25519, ChaCha20, Poly1305, etc.), + **very small codebase** (on the order of a few thousand lines), **which reduces attack surface and configuration errors.**
- **IPsec is highly configurable** (many modes and algorithms), which is powerful but makes it complex and more prone to misconfiguration, with much larger implementations.
- **TLS VPNs inherit TLS crypto agility and complexity, including certificate chains and cipher suite negotiation,** plus the VPN application layer on top (e.g., OpenVPN using OpenSSL).

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between IPSec, Wireguard, TLS VPN – What are the criteria to consider ?

3. **Deployment, NAT traversal, and use cases**

- **WireGuard: simple to configure** (public key–based, fixed parameters) and works well over UDP, with built-in roaming that updates peers' endpoints automatically, -> excellent for mobile clients.
- **Ipsec: de facto standard for site-to-site tunnels between routers and firewalls** and is widely supported in enterprise gear, but **configuration (IKE, policies, modes) is nontrivial**.
- **TLS VPNs: shine for remote access across restrictive networks** because **they can run over HTTPS ports** and look like normal web traffic, easing traversal of proxies and firewalls.

4. **Security posture and operational fit**

- **WireGuard's simplicity (fixed crypto, small code, minimal options) favors easier audits and lower misconfig risk**, but its design ties identity to keys and AllowedIPs, which influences how you model multi-user and multi-tenant access.
- **IPsec's maturity, standards base, and integration** with network gear make it a strong choice for large corporate interconnects and environments **needing standardized, vendor-agnostic interoperability**.
- **TLS VPNs align well with application-centric remote access, web SSO, and environments already heavily invested in PKI and HTTPS inspection**, at the cost of more overhead and larger attack surface.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

1. **Cryptography**

- Client certificates for machine authentication, when using a VPN. Certificates have several advantages over Pre-Shared Keys (PSKs), including the ability to revoke just one certificate on your network and to store private keys securely

2. **Integrated vs third-party VPN clients**

Third-party VPN client increases

- **The risk of poor integration with the operating system** (e.g. data may be sent outside the VPN.
- **The number of software packages to be kept up to date**, adding to the likelihood that some out-of-date software will be in use.

3. **Forced vs optional VPN**

- **Forced VPN**: Routes all traffic through VPN for full protection; requires client enforcement or firewall rules to block non-VPN connections.
- **Forced risks/benefits**: No internet if VPN fails (unless disabled); prevents data leaks but may conflict with captive portals on public Wi-Fi.
- **Optional VPN:** Users can disable it, allowing flexibility but risking data exposure and evasion of monitoring/auditing.
- **Trade-off:** Forced ensures security compliance; optional suits usability but introduces bypass risks.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

VPN must establish a connection, remain connected while the device is in use, and reconnect if the connection is temporarily lost

Automatic, triggered, or manual ?

- **Automatic VPNs are brought up by the device whenever a network connection is requested by software** on the device.
- **Triggered VPNs are brought up whenever certain network connections from a defined list are made** (internal intranet sites, for example).
- **Manual VPNs require the user of the device to initiate the VPN by explicitly deciding to take an action** (such as launching an application and clicking connect).

Automatic ≠ forced

- **VPN initiation (automatic, triggered, manual) affects usability more than security,** based on whether VPN is forced or optional.
- **Forced VPN with manual start creates poor UX:** no connectivity until user intervenes**.**
- **Optional VPN with manual start risks compromise:** exposure to local attackers on untrusted networks while disconnected.
- Recommendation: **Use automatic VPN initiation.**

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Full-device vs per-app VPN

- Some OS and third-party apps support **per-app VPN configuration**, routing only specific apps through the VPN.
- **Ideal for BYOD scenarios**: keeps **personal app traffic off** corporate network.
- **Benefits: blocks malicious personal apps from attacking corporate network**; **limits bandwidth use** by data-heavy personal apps.
- **Allows latency-sensitive apps** (e.g., VoIP) to bypass VPN for lower latency.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Split tunnelling

- Split tunnelling lets **some traffic use the VPN** while other traffic connects directly.
- It works by **routing only specific network ranges** (e.g., internal IPs) through the VPN.
- All other **traffic uses the system's normal internet gateway**.
- **Native VPN clients rarely support split tunnelling**; they have limited configuration options.
- Windows can support it via custom routing rules, but **mobile clients usually cannot.**
- Some **third-party VPN clients do support split tunnelling**.
- Enabling split tunnelling increases the risk of data exposure and potential attacker pivoting into internal networks.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Managed tunnelling

- Managed tunnels allow specific services to access the endpoin,t outside the VPN by routing traffic to particular endpoints, avoiding the full VPN path.
- Sensible use cases include **reducing network load from video conferencing** or **enabling apps that require direct network communication, like Wi-Fi captive portal helpers.**
- Only recommended when the service provider guarantees:
  - Connections **are protected equivalently to the VPN** (e.g., mutual TLS authentication).
  - Service uses **dedicated IP endpoints**, ensuring only that specific traffic bypasses the VPN.
- Requires a clear business need, such as high-bandwidth video conferencing services.
- Also advised for Wi-Fi captive portal functionality.

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Captive Portals and VPN

- **Captive portals are the login pages present on some public Wi-Fi networks**. To use a captive portal, the device is required to establish a direct connection from a web browser to the portal before it has established a VPN connection.
- The user can disable any forced VPN configuration
- This allows the user to manually navigate to the portal in their main web browser.
- The platform itself can detect the presence of a captive portal
- The user is then presented with a captive portal assistant application to authenticate with before re-establishing the VPN
- The use of a captive portal assistant application is less risky

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Captive Portals and VPN

- **Captive portals are the login pages present on some public Wi-Fi networks**. To use a captive portal, the device is required to establish a direct connection from a web browser to the portal before it has established a VPN connection.
- The user can disable any forced VPN configuration
- This allows the user to manually navigate to the portal in their main web browser.
- The platform itself can detect the presence of a captive portal
- The user is then presented with a captive portal assistant application to authenticate with before re-establishing the VPN
- The use of a captive portal assistant application is less risky

DEVICE SECURITY GUIDANCE

VPN PROTOCOLS

You are confronted to a choice between VPN – What are the criteria to consider ?

Conclusions- Security by Design and Security by Defualt Choices

- Use the **IPsec** protocol to enjoy a wide variety of inter-operable products.
- Use **certificate authentication**. Store private keys in hardware-protected storage (TPM or TEE) if possible.
- Use the **native client** for your particular platform(s), if possible.
- Use a **forced VPN** to ensure apps cannot evade enterprise monitoring solutions (if you use them).
- Use a VPN which **automatically connects,** so the device user is not required to manually enable it.
- Use a **full-device VPN** and **avoid split tunnelling** to minimise the risk of data leaking outside the VPN.
- Use the platform's built-in captive portal helper

DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

Important security issues to consider when designing remote access for enterprise users.

- Traditional VPN-based "walled garden" model or zero trust architecture.

- Traditional VPN remote access can work well when you still host significant on-premises resources.
- If few or no on-premises services, a zero trust model can be very effective.
- Hybrid model not excluded !
  - If you must use a traditional VPN model, **applying zero trust principles and controls on top** of it may will reduce additional risks and ease later migration to full zero trust.

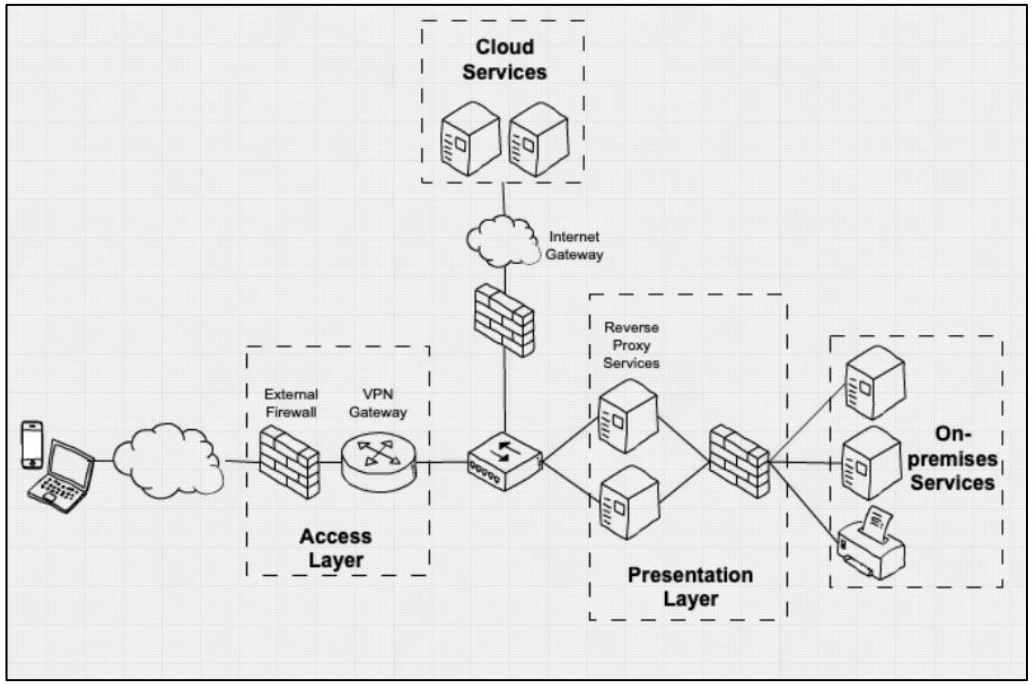
DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

1. Traditional VPN-based remote access architecture

Layers walled garden are:

- **The access layer,** authenticating remote devices.
  - Network traffic from remote devices is trapped here unless it can subsequently authenticate to local services
- **The presentation layer**, brokering access to internal services based on corporate policy
- **A core network**, comprising of on-premise services
- An **internet gateway**, providing proxy access to remote websites and enterprise cloud services .

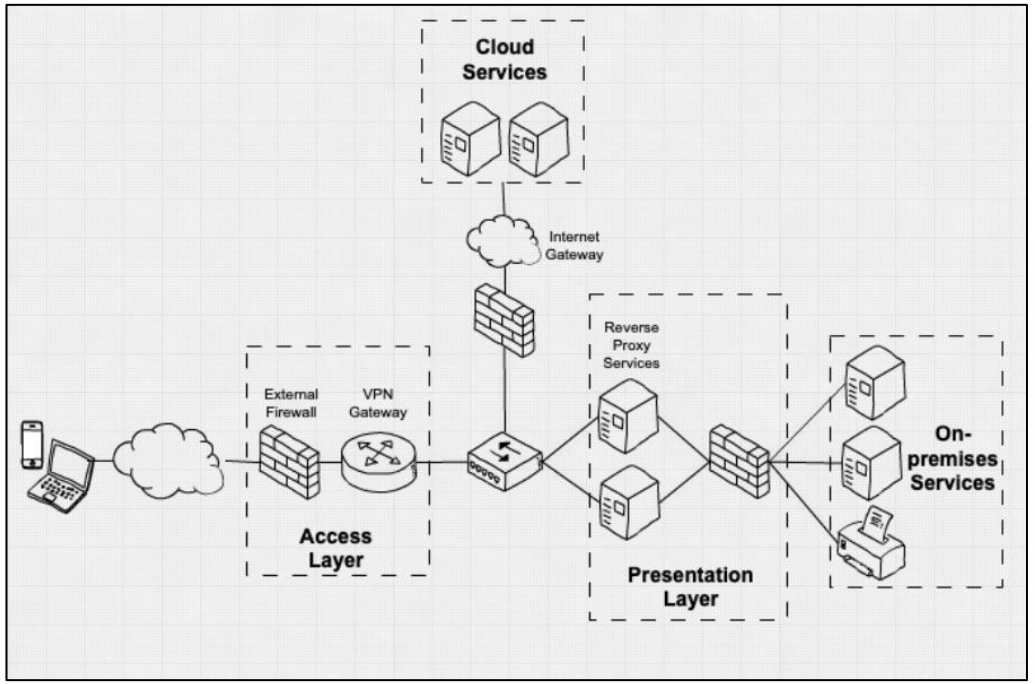


DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

1. Traditional VPN-based remote access architecture

- Traditional VPN architecture requires **both user and machine authentication before granting access** to enterprise services.
- These authentications must be linked: a specific user can only access services from their assigned device.
- The access layer handles machine authentication, while the presentation layer manages user authentication.



DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

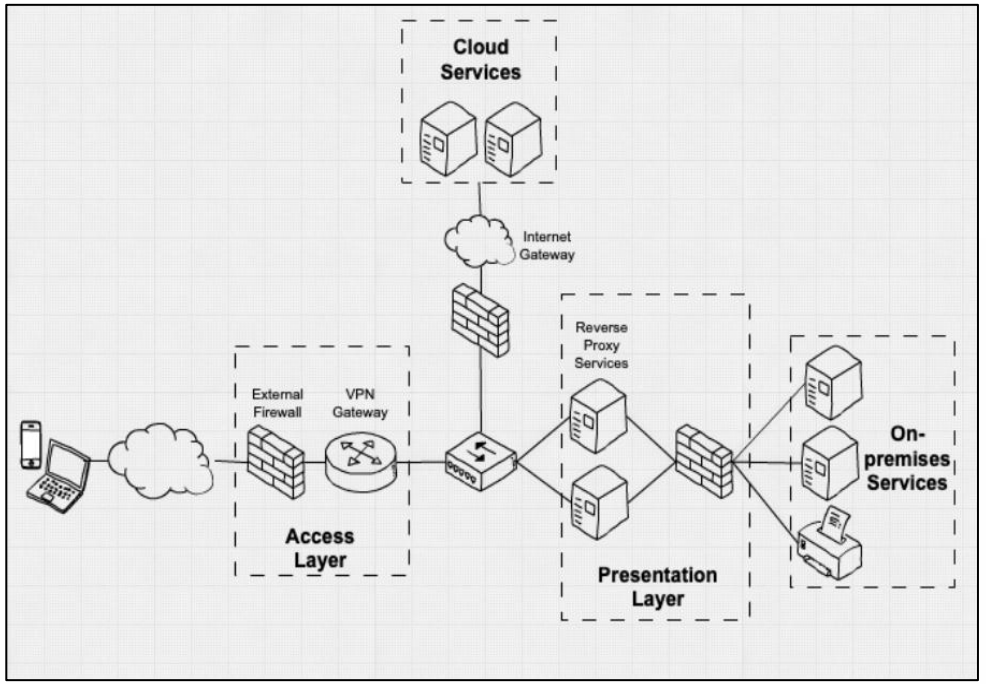
1. Traditional VPN-based remote access architecture

Presentation layer role:

- **Shows a subset of enterprise services to remote devices** and authenticates users upon connection.

- **Insert a layer between remote devices and core services**, by breaking end-to-end encryption (e.g., via reverse proxy or load balancer). Why ? A compromised remote device can't directly reach core enterprise services; traffic must pass through the controlled presentation layer, where it can be inspected, logged, or blocked

- **layer of abstraction example:** Use of a read-only domain controller (RODC) or remote desktop/app services or a reverse authenticating proxy brokering access (handles authentication before forwarding requests). It is called reverse because: Sits on the server side (at your network edge/DMZ)+ External clients connect to it unknowingly (appears as the "server").



VRIJE UNIVERSITEIT BRUSSEL
UNIVERSITE LIBRE DE BRUXELLES

DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

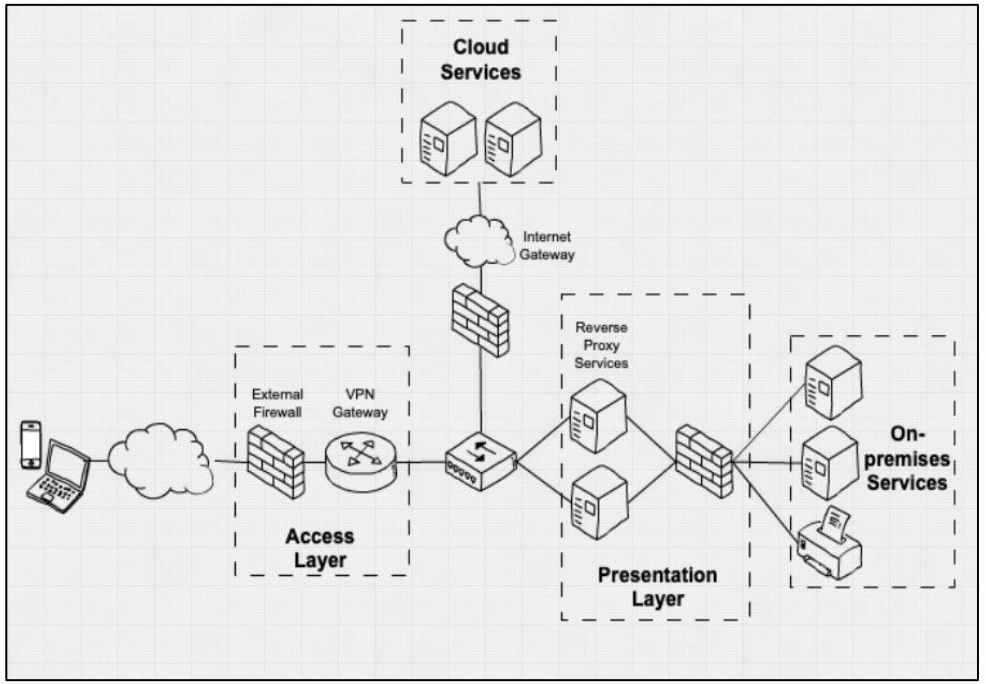
1. Traditional VPN-based remote access architecture

Presentation layer role:

- **Shows a subset of enterprise services to remote devices** and authenticates users upon connection.

- **Insert a layer between remote devices and core services**, by breaking end-to-end encryption (e.g., via reverse proxy or load balancer). Why ? A compromised remote device can't directly reach core enterprise services; traffic must pass through the controlled presentation layer, where it can be inspected, logged, or blocked

- **layer of abstraction example:** Use of a read-only domain controller (RODC) or remote desktop/app services or a reverse authenticating proxy brokering access (handles authentication before forwarding requests). It is called reverse because: Sits on the server side (at your network edge/DMZ)+ External clients connect to it unknowingly (appears as the "server").



VRIJE UNIVERSITEIT BRUSSEL
UNIVERSITE LIBRE DE BRUXELLES

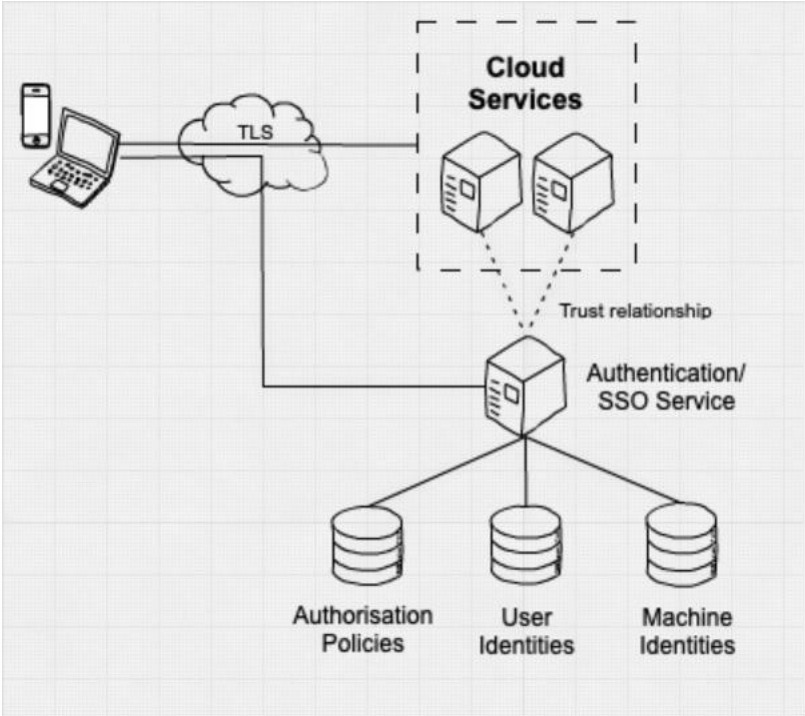
DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

2. Zero Trust Architecture

- **A zero trust architecture removes the inherent trust from the network** while building confidence in each request:
  - through building context through strong authentication, authorisation, device health, and value of the data being accessed.

- **Preparing for a zero trust architecture**
  - Important to have a strong device configuration but single strong user identity source is foundational for zero trust, enabling reliable access rules.
  - Consolidate **user roles/accounts in one organizational directory (source of truth) linked to individuals**.
  - Use **granular roles for precise access control**.
  - Directory integrates across all services (internal/external) for consistent enforcement.



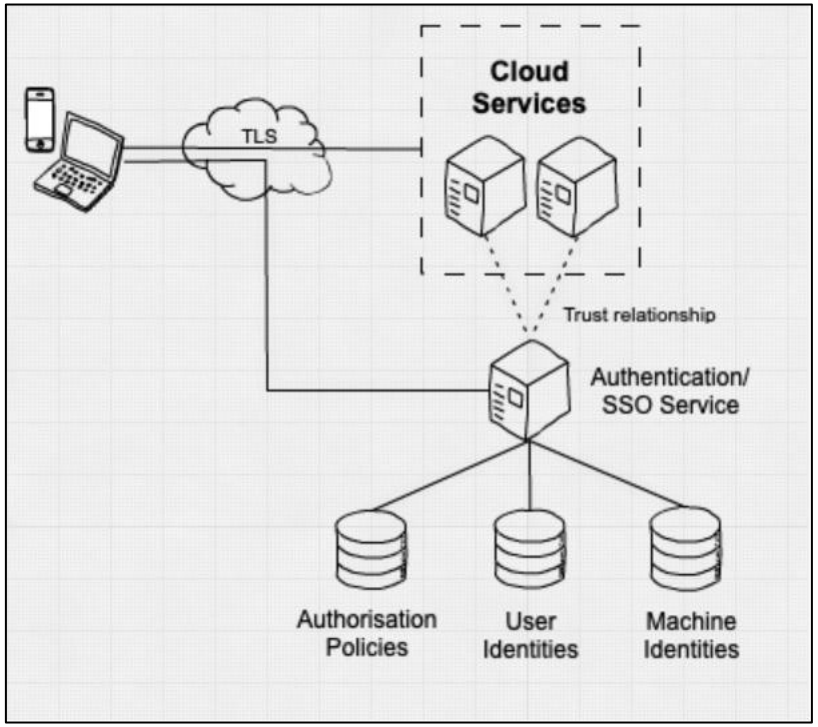
DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

2. Zero Trust Architecture

- **User authentication**
  - Strong authentication required: **Use multi-factor authentication (MFA)** to protect against password attacks.
  - **Enterprise SSO integration**: Authentication flows through a single sign-on service tied to your single user identity source.
  - **Benefits:** Automates/simplifies credential management; streamlines joiners/movers/leavers processes.

- **Machine authentication**
  - **Concurrent authentication:** Machine authentication can occur simultaneously with user authentication and may be implicit.
  - **Trust passing example**: A single-user device that authenticates the user can forward that trust during its own machine authentication to services.
  - **Secure credentials:** Machine auth credentials should be tightly bound to the device, ideally using hardware-protected storage.



DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

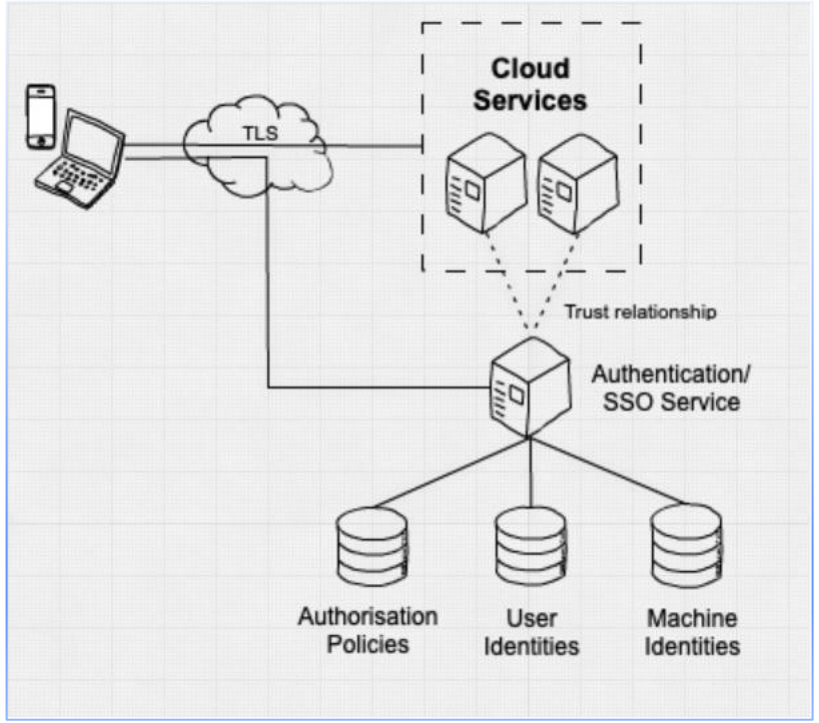
2. Zero Trust Architecture

- **Additional context, such as policy compliance and device health**

- **MDM integration:** Authentication services connect with Mobile Device Management (MDM) to verify device compliance with corporate policy before granting data access.

- **Compliance mechanism:** Issue short-lived certificates to compliant devices via MDM; these certificates enable device authentication, implicitly confirming policy adherence.

- **Device health attestation:** Emerging feature in auth services for strong proof of secure boot and ongoing good state; enable it if supported in your environment.



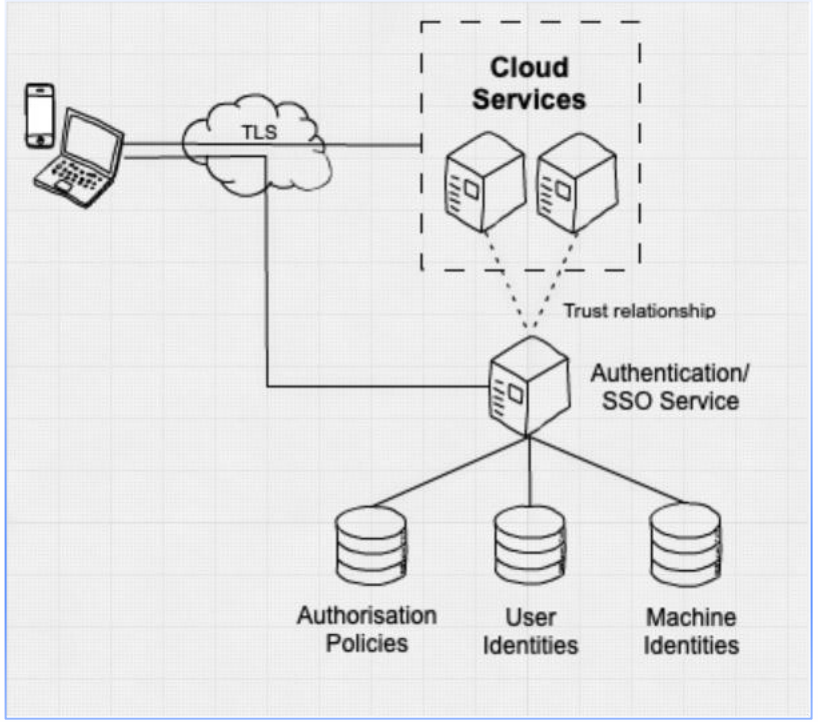
DEVICE SECURITY GUIDANCE

NETWORK ARCHITECTURE

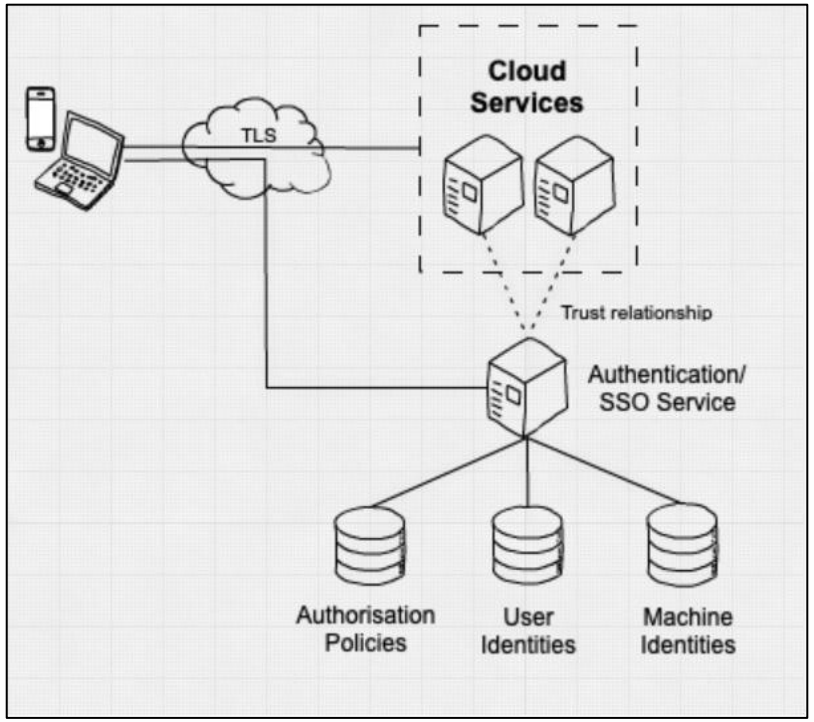
2. Zero Trust Architecture

Authorisation policies to access an application

- **Traditional VPN:** Presentation layer blocks direct access to sensitive enterprise apps from remote devices via network controls**.**
- **Zero trust:** No network routing control, so authorization happens at authentication points (e.g., reverse proxy or SSO issuing tokens).
- **Policy enforcement:** Services deny access if requests violate policy (non-compliant user/device).
- **Preconditions in auth:** Selective requirements like MFA only for certain apps; allow outdated devices for MDM but block email access.



2. Zero Trust Architecture

Access control policies within an application

- Zero trust adds rich context to decisions to grant access to resources to authorized users
- **Granular auth examples:** Require MFA for sensitive documents in a file store, but single-factor for low-security ones—ideal for BYOD where personal devices where personal devices may be allowed to access a subset of corporate data.
- **Context passing:** Authentication service shares authorization details (e.g., MFA status, device info) to apps via SAML or OpenID Connect**.**
- **Implementation note:** Not widely supported yet; verify compatibility with your auth service and app providers.